

=====

PCI DSS Manual - Lexington Commons Weco

=====

This PCI DSS policy applies exclusively to the HOA web portal's payment initiation page and supporting AWS hosting environment. The Cardholder Data Environment (CDE) consists solely of the hosted payment fields provided by [Authorize.net](https://authorize.net). No HOA system stores, processes, or transmits CHD or SAD.

This policy is aligned with PCI DSS v4.0 requirements.

This policy is reviewed annually by the Web Administrator and formally approved by the HOA Board.

=====

SECTION 1: NETWORK SECURITY POLICIES AND PROCEDURES (PCI Requirement 1)

=====

Effective Date: 07/20/2025

Last Reviewed: 07/20/2025

Review Cycle: Annually (Policies) / Every 6 Months (AWS Audits)

1. PURPOSE & SCOPE

This policy outlines how the HOA secures the cloud network and hosting environment for our member portal. While cardholder data is handled entirely by Authorize.net and is never stored, processed, or transmitted on HOA infrastructure, these controls protect the portal's integrity from unauthorized access.

2. ROLES, RESPONSIBILITIES, & ACCESS CONTROL (PCI 1.2.5)

- * The Web Administrator is responsible for maintaining this policy, managing AWS Security Groups, and restricting access to network configuration tools.
- * AWS Console access is restricted strictly to authorized administrators using strong, unique passwords and mandatory Multi-Factor Authentication (MFA). This ensures configuration rule sets are secured from unauthorized modification.

3. ARCHITECTURE & DATA FLOW DIAGRAMS (PCI 1.2.3 & 1.2.4)

- * Network and Data-Flow diagrams are maintained as separate visual attachments to this manual (stored securely alongside this file).
- * Network Diagram Scope: Illustrates the boundary between untrusted networks (the public internet) and our trusted cloud network (AWS VPC). It details the path from the AWS Internet Gateway, through the Web Server Security Group, to the isolated Database Security Group. There are absolutely NO corporate, guest, or administrative wireless networks connected to or within this cloud environment; therefore, wireless entry is denied by default.
- * Data-Flow Diagram Scope: Explicitly maps the path of member account data.

It illustrates that cardholder data flows directly from the member's browser to Authorize.net via secure implementation (iframe/redirect) and completely bypasses the HOA website and database servers.

- * Diagram Maintenance: These diagrams are reviewed annually and updated immediately following any structural modification to the web or network environment.

4. APPROVED PORTS, PROTOCOLS, AND TRAFFIC RESTRICTIONS (PCI 1.3 & 1.4)

The HOA portal enforces a strict "Default Deny" posture for both inbound and outbound traffic. Any traffic not explicitly defined below is blocked automatically by AWS Network Security Controls.

A. INBOUND TRAFFIC RULES (Untrusted to Trusted)

- * All inbound traffic from the public internet is blocked by default.
- * Explicit Inbound Exceptions Allowed:
 - Port 443 (TCP/HTTPS): Allowed from anywhere (0.0.0.0/0) to serve the portal.
 - Port 80 (TCP/HTTP): Allowed from anywhere (0.0.0.0/0) exclusively to redirect to 443.

B. OUTBOUND TRAFFIC RULES (Trusted to Untrusted)

- * Outbound traffic from the internal network to the internet is restricted to essential operational dependencies.
- * Explicit Outbound Exceptions Allowed:
 - Port 443 (TCP/HTTPS): Allowed out to Authorize.net API endpoints [and AWS system update repositories] to validate payment transactions and maintain system software.
 - All other outbound destinations and ports are explicitly denied.

C. INTERNAL TRAFFIC RULES (Trusted Zone Isolation)

- * The HOA Database is completely isolated from the public internet.
- * Inbound traffic to the database is restricted exclusively to the private IP/Security Group ID of the Web Server on the designated database port (e.g., Port 3306). All other internal lateral traffic is denied.

5. MAINTENANCE, REVIEWS, AND CHANGE CONTROL (PCI 1.2.2, 1.2.8 & 6.5.1)

- * Verification of Significant Changes: Upon completion of any major system or code deployment, the Web Administrator will perform a verification audit to confirm that all applicable PCI DSS baselines remain actively enforced on the changed environment. All associated system documentation and configurations will be updated accordingly.
- * Bi-Annual Active Audit: At least once every six months, the Web Administrator will log into the AWS Console to review all active Security Groups and Network ACLs. The administrator will confirm that active configurations match the approved matrix in Section 4 and that no unauthorized rules exist.
- * Consistency Check: During the bi-annual audit, the administrator will verify that our visual diagrams and this text manual remain perfectly synchronized with the live AWS settings.
- * Formal Change Control Process: Any modification to AWS network configurations

must adhere to the following change management protocol prior to deployment:

1. Documentation & Business Justification: Define the exact change and reason.
2. Security Impact Assessment: Verify no database exposure or card data leaks.
3. Rollback Plan: Document steps to immediately reverse the change if it fails.
4. Testing & Sign-off: Test the change safely and obtain Web Administrator approval.
5. Logging: Maintain a running digital log of changes (dates, impact, authorization).

6. INTERNAL IP EXPOSURE AND ROUTING (PCI 1.4.5)

- * Public disclosure of internal AWS IP addresses, VPC routing tables, or private network topologies is strictly prohibited.
- * Application error handling must be configured to suppress verbose system logs or stack traces to public visitors, ensuring no internal infrastructure data leaks.

7. END-POINT SECURITY FOR NETWORK ADMINISTRATION (PCI 1.5 & 1.5.1)

- * "Dual-homed" risks are minimized by securing all computing devices used by the Web Administrator to access the AWS Console.
- * Any device used for HOA portal administration must adhere to the following:
 1. Personal/Local Firewalls: Must be active and non-alterable during sessions.
 2. Anti-Malware: Endpoint security controls must be running and up to date.
 3. Access Management: Admin sessions to AWS require strong passwords and MFA.

SECTION 2: SECURE SYSTEM CONFIGURATIONS (PCI Requirement 2)

Effective Date: [Insert Date]

Last Reviewed: [Insert Date]

Review Cycle: Annually

1. PURPOSE & SCOPE

This policy outlines the secure configuration and hardening standards applied to all infrastructure components supporting the HOA web portal.

2. DISTRIBUTION & MAINTENANCE (PCI 2.1.1)

- * The Web Administrator maintains this configuration policy. It is reviewed annually and communicated to any authorized technical personnel or board members.

3. COMPONENT ISOLATION AND PRIMARY FUNCTIONS (PCI 2.2.3)

- * The HOA portal strictly isolates primary system functions to prevent lateral exploitation.
- * The public-facing Web Application and the underlying Member Database are decoupled. They reside on distinct, isolated environments [e.g., Separate EC2 instances / AWS RDS and AWS Amplify]. Insecure or unrelated services (such as public mail servers or FTP servers) are prohibited from running on these components.

4. SYSTEM PARAMETER HARDENING (PCI 2.2.6 & 1.4.4)

- * Default configuration settings provided by vendors must be altered prior to deployment.
- * All unnecessary scripts, protocols, and system utilities are deleted or disabled.
- * System components containing member or property records are restricted to private subnets and are completely inaccessible from untrusted networks. No actual cardholder data is ever written to or stored on any system component.

5. WIRELESS ENVIRONMENT KEY MANAGEMENT (PCI 2.3.2)

- * As established in Section 1, there are NO wireless networks connected to, or transmitting data within, the AWS cloud hosting environment.
- * In the event that a wireless network is introduced into the administrative scope in the future, wireless encryption keys will be rotated immediately if any personnel with knowledge of the key leave their role, or if a compromise is suspected.

SECTION 3: PROTECTION OF STORED ACCOUNT DATA (PCI Requirement 3)

Effective Date: [Insert Date]

Last Reviewed: [Insert Date]

Review Cycle: Annually (Policies) / Every 3 Months (Scrubbing Audits)

1. ACCOUNT DATA RETENTION AND ELIMINATION STANDARDS (PCI 3.1 & 3.2.1)

- * Zero-Storage Mandate: The HOA web portal and its underlying AWS database strictly enforce a zero-retention policy for Cardholder Data (CHD) and Primary Account Numbers (PAN). All payment inputs are handled natively via Authorize.net integration (iframe/redirect).
- * Sensitive Authentication Data (SAD): The storage of SAD (including CVV/CVC codes, PINs, and magnetic stripe data) is strictly prohibited under all circumstances, both before and after transaction authorization (PCI 3.3).
- * Quarterly Verification: At least once every three months (quarterly), the Web Administrator will audit application databases and error logs to ensure no accidental account data or plain-text payment inputs have been written to disk. Any anomalous data discovered will be securely deleted immediately using cryptographically secure erasure.

2. CRYPTOGRAPHIC KEY MANAGEMENT SCOPE (PCI 3.6 & 3.7)

- * Because the HOA infrastructure never stores cardholder data, local cryptographic key management frameworks for stored account data are completely out of scope.

3. DATA CLASSIFICATION

- * Public Data, Internal HOA Data, Sensitive Member Data
- * No CHD or SAD is ever stored

=====

SECTION 4: PROTECTION OF DATA IN TRANSMISSION (PCI Requirement 4)

=====

Effective Date: [Insert Date]

Last Reviewed: [Insert Date]

Review Cycle: Annually

1. PURPOSE & DISTRIBUTION (PCI 4.1.1)

This policy defines the standards for protecting member data as it moves across the public internet to our AWS hosting environment and onward to Authorize.net.

This policy is kept up to date and known to the Web Administrator.

2. STRONG CRYPTOGRAPHY PROTOCOLS (PCI 4.2.1.a - 4.2.1.d)

- * HTTPS Enforcement: All connections to the HOA portal must utilize Transport Layer Security (TLS). Unencrypted HTTP traffic on Port 80 is instantly rejected and redirected to HTTPS.
- * Cipher and Protocol Restrictions: The AWS hosting configuration (via AWS Certificate Manager / Load Balancers / CloudFront / Amplify) is explicitly configured to enforce a minimum baseline of TLS 1.2 or TLS 1.3. Legacy protocols, including SSL v2, SSL v3, TLS 1.0, and TLS 1.1, are disabled entirely to prevent downgrade fallback attacks. Only industry-standard strong encryption algorithms and appropriate key sizes (e.g., AES-256) are permitted.
- * Certificate Management: Certificates used to protect data in transit must be issued by a trusted, globally recognized Certificate Authority (CA). The HOA utilizes [AWS Certificate Manager (ACM)], which automatically tracks validity schedules and renews certificates prior to expiration or revocation.

3. WIRELESS NETWORKS (PCI 4.2.1.2)

- * As established in previous sections, no wireless networks connect to or operate within the AWS CDE. No payment data or PAN is ever transmitted across an HOA-managed wireless network.

=====

SECTION 5: MALWARE AND PHISHING PROTECTION (PCI Requirement 5)

=====

Effective Date: [Insert Date]

Last Reviewed: [Insert Date]

Review Cycle: Annually

1. PURPOSE & DISTRIBUTION (PCI 5.1.1)

This policy defines anti-malware and anti-phishing controls to protect the HOA's administrative infrastructure.

2. TARGETED RISK ANALYSIS & MALWARE ASSESSMENT (PCI 5.2.3.1 & 5.3.2.1)

- * Cloud Server Risk Profile: The HOA portal utilizes managed cloud infrastructure [e.g., AWS Amplify / AWS RDS / isolated containerized environments]. Because these components do not possess user-accessible file systems or execute traditional binaries, they are designated as "Not at Risk" for traditional malware infection.
- * Evaluation Schedule: The Web Administrator performs a formal risk evaluation every 12 months to verify that the system architecture remains isolated from malware entry vectors.

3. REMOVABLE MEDIA EXCLUSION (PCI 5.3.3)

- * The cloud-hosted production environment does not permit or support the use of physical, removable electronic media. This control is designated as N/A.

4. ANTI-PHISHING CONTROLS (PCI 5.4.1)

- * All HOA email accounts utilized for administrative portal communication or AWS console access must operate via a cloud provider [e.g., Google Workspace / M365] with automated, active anti-phishing, spoofing detection, and spam filtering enabled natively.

SECTION 6: SECURE SOFTWARE DEVELOPMENT (PCI Requirement 6)

Effective Date: [Insert Date]

Last Reviewed: [Insert Date]

Review Cycle: Annually

1. PURPOSE & DISTRIBUTION (PCI 6.1.1)

This policy establishes secure coding baselines for the bespoke HOA portal application, ensuring that changes do not introduce high-risk vulnerabilities.

2. SECURE DEVELOPMENT LIFE CYCLE & TRAINING (PCI 6.2.1 & 6.2.2)

- * Secure Frameworks: The portal is built using secure development frameworks. Security considerations are embedded into design, testing, and deployment.
- * Annual Training: Anyone developing code for the portal must complete secure software training at least once every 12 months, specifically covering secure design, coding techniques, and vulnerability detection relative to the languages in use (e.g., web-facing languages and SQL frameworks).

3. VULNERABILITY MITIGATION & SECURE CODING STANDARDS (PCI 6.2.4.a - 6.2.4.f)

All custom programming code deployed to the HOA platform must be engineered to explicitly prevent common application software vulnerabilities by adhering to the following coding practices:

- * Injection Prevention (SQL/LDAP): All database interactions must use parameterized queries, prepared statements, or object-relational mapping (ORM) tools.

Raw, concatenated user input must never be passed directly to the database.

- * Data Structure Integrity: Enforce strict input validation, data length validation, and type-checking to prevent buffer manipulation or payload corruption exploits.
- * Cryptographic Standards: Implement only industry-vetted cryptographic protocols (e.g., bcrypt/Argon2 for member passwords). Custom or home-grown encryption algorithms are strictly prohibited.
- * Business Logic, XSS, & CSRF Prevention: All user-supplied data displayed on the portal must be thoroughly sanitized and HTML-encoded before being rendered to the browser. Anti-CSRF security tokens must be utilized for all authenticated state-changing requests.
- * Access Control Controls: Enforce strict server-side validation for all portal sessions. A client-side hide/show restriction is never trusted; the API/database must verify permission sets before serving or modifying property/member data.
- * Vulnerability Reviews: Code changes must be manually reviewed for high-risk flaws prior to production deployment via the change control log defined in Section 1.

4. SOFTWARE INVENTORY AND VULNERABILITY MANAGEMENT (PCI 6.3.1 & 6.3.2)

- * The Web Administrator maintains a running inventory of all custom code modules, operating systems, and third-party dependencies/libraries supporting the portal.
- * Security alerts from industry-recognized sources (e.g., AWS Security Hub, National Vulnerability Database, GitHub Dependabot) are monitored.
- * Identified vulnerabilities are ranked by severity (Low, Medium, High, Critical). Any dependency flagged as High-Risk or Critical must be patched or upgraded within 30 days of discovery.

5. PUBLIC-FACING APPLICATION PROTECTION (PCI 6.4.1 & 6.4.2)

- * Automated Technical Shielding: To continually detect and prevent web-based attacks, the HOA portal implements [AWS WAF (Web Application Firewall)] directly in front of all public-facing application resources.
- * Firewall Status: The AWS WAF is kept actively running, configured to block known attack vectors (including the OWASP Top 10), and produces automated audit logs that alert the Web Administrator to security anomalies.

6. CLIENT-SIDE SCRIPT INTEGRITY & INVENTORY (PCI 6.4.3.a - 6.4.3.c)

- * Script Authorization & Inventory: A strict list of all JavaScript files authorized to run on the portal payment-launch page is maintained below:
 1. [Insert Local Web App Script Name, e.g., main.js] - Renders portal layout.
 2. Authorize.net Accept.js / Iframe - Facilitates secure payment transaction tokenization.
- * Integrity Assurance: To prevent browser-layer script manipulation or code injection:
 1. Content Security Policy (CSP): The web application sends HTTP headers restricting script execution strictly to authorized domains (e.g., self and *.authorize.net).
 2. Subresource Integrity (SRI): Third-party scripts are embedded using cryptographic hashes to ensure that the code has not been altered at the source.

=====

SECTION 7: ACCESS CONTROL AND LEAST PRIVILEGE (PCI Requirement 7)

=====

Effective Date: [Insert Date]

Last Reviewed: [Insert Date]

Review Cycle: Annually (Policies) / Every 6 Months (Access Audits)

1. LEAST PRIVILEGE AND ACCESS ASSIGNMENT (PCI 7.2.3 & 7.2.5)

- * Access to all HOA system components, the member database, and the AWS Console is strictly restricted based on business need-to-know and the principle of least privilege.
- * Privileges are limited exclusively to the specific systems, files, or applications required for an individual's operational role. All access level escalations must be explicitly approved in writing by the Web Administrator.

2. BI-ANNUAL USER ACCESS REVIEWS (PCI 7.2.4)

- * At least once every six months, the Web Administrator will formally review all active user, administrative, and third-party developer accounts inside AWS and the portal backend.
- * Any inappropriate, obsolete, or excessive access privileges discovered will be revoked immediately. The HOA board will formally acknowledge and sign off that the remaining access privileges are correct and appropriate.

=====

SECTION 8: IDENTITY AND AUTHENTICATION MANAGEMENT (PCI Requirement 8)

=====

Effective Date: [Insert Date]

Last Reviewed: [Insert Date]

Review Cycle: Annually

1. PURPOSE & DISTRIBUTION (PCI 8.1.1)

This policy defines identity verification baselines for individuals administering the HOA portal environment to ensure total accountability for all actions taken.

2. UNIQUE USER IDENTIFICATION (PCI 8.2.1 & 8.2.2)

- * Individual Accountability: Every administrative user, technical contractor, or board member granted access to the cloud environment must be assigned a unique, individual user ID.
- * Generic/Shared IDs Prohibited: The use of generic, shared, or group logins (e.g., a shared "admin" account) is strictly prohibited. In exceptional operational emergencies where a shared account is required, its use must be approved by management, restricted to a finite timeframe, and the true identity of the person using it must be logged so that every action remains entirely attributable.

3. PASSWORD AND COMPLEXITY STANDARDS (PCI 8.3.4 - 8.3.9)

- * All administrative, developer, and database accounts must enforce a strict, automated password security profile:
 1. Minimum Length: Passwords must be at least 12 characters long.
 2. Composition: Must contain a mix of both numeric and alphabetic characters.
 3. History: Users are barred from reusing any of their last 4 passwords.
 4. First-Time Use: Passwords generated for initialization or resets must be cryptographically unique and forced to change immediately upon first login.
- * Lockout Mechanics: Accounts must automatically lock out after a maximum of 10 consecutive invalid authentication attempts. The lockout duration must persist for a minimum of 30 minutes or until cleared by the Web Administrator.
- * Verification Prior to Modification: Before any credential or MFA factor is modified, the true identity of the requesting user must be verified via secondary verification.
- * Non-MFA Rotation: If any administrative account operates strictly on a single authentication factor, its password must be rotated every 90 days. (Note: The HOA bypasses this by enforcing global MFA for all administrative endpoints).

4. MULTI-FACTOR AUTHENTICATION (MFA) MANDATE (PCI 8.4.1 - 8.5.1)

- * Global Enforcement: MFA is strictly mandatory for all console and non-console administrative access paths into the AWS cloud hosting environment and database.
- * MFA Architecture: Our authentication system requires the validation of two distinct independent factors: Something You Know (12+ character password) and Something You Have
(Time-based One-Time Password via a software Authenticator App).
- * Bypass Restrictions: Success of both factors is strictly required before access is granted. MFA cannot be bypassed or disabled by any user profile.

5. APPLICATION AND SYSTEM ACCOUNT HYGIENE (PCI 8.6.1 - 8.6.3)

- * Non-Interactive Restriction: System/service accounts utilized for software-to-software communication are prohibited from performing interactive programmatic logins.
- * No Hardcoding: Administrative credentials, database connection strings, and Authorize.net API secret keys must NEVER be hardcoded inside application source code, plain-text configuration files, or build scripts.
- * Injection of Secrets: All backend system secrets must be loaded dynamically at runtime utilizing protected environment variables or an isolated cloud secrets repository [e.g., AWS Secrets Manager].

=====

SECTION 9: PHYSICAL ACCESS SECURITY (PCI Requirement 9)

=====

Effective Date: [Insert Date]
 Last Reviewed: [Insert Date]
 Review Cycle: Annually

1. PHYSICAL ENVIRONMENT EXEMPTION (PCI 9.1 - 9.4)

- * The HOA portal infrastructure is entirely cloud-hosted within an AWS environment. The HOA maintains no physical computing facilities, on-premise servers, or server closets within the scope of this evaluation.
- * Physical facility entry security, environmental hardware controls, and hardware asset tracking are managed strictly by Amazon Web Services as part of their cloud infrastructure security compliance models.
- * Zero Card Media Policy: Because the HOA portal utilizes an inline redirect/iframe to hand off transaction processing to Authorize.net, no cardholder data ever enters HOA custody. The creation, storage, distribution, or handling of offline physical backup media containing cardholder data is strictly prohibited.

=====

SECTION 10: AUDIT LOGGING AND MONITORING (PCI Requirement 10)

=====

Effective Date: [Insert Date]

Last Reviewed: [Insert Date]

Review Cycle: Annually (Policies) / Daily Automated Alarms

1. PURPOSE & DISTRIBUTION (PCI 10.1.1)

This policy defines the structural logging and auditing baselines for all AWS infrastructure and custom database systems supporting the HOA portal.

2. AUDIT LOGGING GENERATION AND RECIPIENTS (PCI 10.2.1 - 10.2.2)

- * Infrastructure Logging: [AWS CloudTrail] is enabled globally across our hosting environment to capture all configuration events and administrative API calls.
- * Monitored Events: Security log events must record the following items:
 1. All administrative logins and execution of elevated privileges (PCI 10.2.1.2).
 2. All invalid logical access attempts and brute-force indicators (PCI 10.2.1.4).
 3. Modifications to credentials, user profiles, or account creation (PCI 10.2.1.5).
 4. Initialization, pausing, or modification of logging services (PCI 10.2.1.6).
 5. Creation and deletion of system-level objects (PCI 10.2.1.7).
- * Log Data Fields: Each logged event must automatically record: unique user identification, type of event, date and time (timestamp), success/failure indicator, event origination IP, and the name of the affected system component.
- * Cardholder Data Scope: No logs track cardholder data, as none enters custody (PCI 10.2.1.1 is N/A).

3. LOG INDESTRUCTIBILITY AND RETENTION (PCI 10.3.1 - 10.3.4 & 10.5.1)

- * Access Restrictions: Read access to system logs is restricted strictly to the Web Administrator based on a job-related need to know.
- * Modification Prevention: Logs are stored using [AWS CloudWatch Logs / Amazon S3] behind strict IAM policies that explicitly prevent the modification or deletion of past records by any standard user or automated process.

* Archive Retention: Logs are dynamically retained for a baseline duration of at least 12 months, with the most recent 3 months immediately active and searchable within the administrative management console.

4. AUTOMATED DAILY REVIEW AND ANOMALY DETECTION (PCI 10.4.1 - 10.4.3)

* Automated Alarms: The HOA utilizes automated metrics [e.g., Amazon CloudWatch Alarms / AWS Security Hub / automated system scripts] to continuously inspect active security event logs.

* Review Cadence: The automated monitoring solution scans system logs daily for anomalies, critical system failures, network security control changes, and sequential authentication failures.

* Incident Escalation: Any security metric trigger or log exception will instantly generate an administrative alert via email to the Web Administrator, requiring immediate triage, resolution, and documentation.

5. NETWORK TIME SYNCHRONIZATION (PCI 10.6.1 - 10.6.3)

* Centralized UTC Clock: All cloud infrastructure components, servers, and databases synchronize their underlying internal system clocks using the [Amazon Time Sync Service].

* Clock Integrity: The time architecture queries industry-standard, atomic Coordinated Universal Time (UTC) reference clocks. System management features restrict clock control settings

strictly to core AWS provider mechanics. Manual, unauthorized modification of time parameters

is technically prohibited and programmatically tracked.

SECTION 11: SECURITY TESTING AND VULNERABILITY ASSESSMENTS (PCI Requirement 11)

Effective Date: [Insert Date]

Last Reviewed: [Insert Date]

Review Cycle: Annually (Policies) / Weekly & Continuous (Tooling)

1. PURPOSE & DISTRIBUTION (PCI 11.1)

This policy outlines the technical evaluation protocols deployed to continuously test and validate the structural security of the HOA cloud environment and portal.

2. WIRELESS MONITORING EXEMPTION (PCI 11.2)

* As established in previous sections, the portal operates strictly within an isolated cloud-hosted AWS framework. There are no local physical wireless networks managed or connected to the infrastructure scope. This section is designated as N/A.

3. VULNERABILITY SCANNING AND UPGRADES (PCI 11.3.2.1)

* Post-Change Appraisals: In the event of a significant structural or architectural

modification to the portal application or network boundaries, an external vulnerability assessment must be executed immediately.

- * Remediation Threshold: Any discovered vulnerability possessing a Common Vulnerability Scoring System (CVSS) score of 4.0 or higher must be remediated via patching or reconfiguration. A clean follow-up rescan must be completed to confirm resolution. Scan records must be archived for 12 months.

4. ANNUAL PENETRATION TESTING METHODOLOGY (PCI 11.4.1 - 11.4.5)

- * Cadence: Comprehensive network-layer and application-layer penetration testing must be conducted at least once every 12 months and after any high-impact upgrade.
- * Testing Scope: The evaluation must encompass the entire public-facing CDE perimeter, verifying network port lockdowns, application-layer protections (including all vulnerabilities defined in Section 6), and data segmentation boundaries separating the private database from untrusted traffic.
- * Tester Qualifications: Testing may be executed by a qualified external vendor or an operationally independent internal resource possessing engineering security competency. Results, exploited proof-of-concepts, and remediation logs must be retained for at least 12 months.

5. INTRUSION PREVENTION AND INTERFACES (PCI 11.5.1)

- * Live Traffic Inspections: To identify and thwart malicious system penetration, the HOA deploys continuous threat detection instrumentation [e.g., Amazon GuardDuty].
- * Alert System: The monitoring engine continuously evaluates edge boundary traffic and generates immediate administrative notifications via email upon detecting indicators of compromise (IoC) or unauthorized network anomalies.

6. CHANGE AND TAMPER DETECTION SYSTEMS (PCI 11.5.2 & 11.6.1.a - 11.6.1.c)

- * Weekly Infrastructure Integrity: Deployment infrastructure features automated build hashes. An integrity checking cadence runs at least once weekly to compare live running portal assets against authorized git repository source hashes, generating alerts for discrepancies.
- * Weekly Payment Page E-Skimming Protection: The HOA implements an automated, technical tamper-detection routine [e.g., automated monitoring checks or a custom tracking script] to evaluate the payment gateway launch page at least weekly.
- * Monitored Metrics: The mechanism programmatically fetches and inspects the client-side payment execution script contents and HTTP security headers (specifically Content Security Policy configurations) to ensure no unapproved alterations have occurred. Any unauthorized deviations trigger immediate security triage.

=====

SECTION 12: SECURITY POLICIES, RISK MANAGEMENT, AND INCIDENT RESPONSE (PCI Requirement 12)

=====

Effective Date: [Insert Date]
Last Reviewed: [Insert Date]
Review Cycle: Annually

1. COMPREHENSIVE POLICY AND ENVIRONMENT SCOPE (PCI 12.1 & 12.5)

* This complete document constitutes the official Information Security Policy of the HOA. The verified scope is restricted exclusively to the AWS cloud infrastructure hosting environment and the portal application code. No cardholder data is permitted inside this defined scope.

2. ADMINISTRATIVE ACCEPTABLE USE POLICY (PCI 12.2)

* Any board member or contractor accessing administrative portal capabilities or the AWS Console must restrict their usage strictly to verified HOA operational tasks.
* Administrative credentials must never be shared, saved in unencrypted local files, or used on public, unsecured networks.

3. TARGETED RISK ANALYSIS MATRIX (PCI 12.3.1)

The HOA performs a formal risk evaluation every 12 months to validate our custom procedural cadences. The baseline risk determinations are defined below:

* Risk Asset 1: AWS Network Security Controls (Security Groups).
- Threatened Vector: Unauthorized structural modifications or creeping access permissions.
- Mitigating Factor: The environment undergoes no routine daily modifications.
- Justification: A 6-month audit cycle minimizes potential exposure windows without creating administrative fatigue for a volunteer board.
* Risk Asset 2: Cloud Managed Servers (AWS Hosting & Databases).
- Threatened Vector: Malicious software / Operating System malware execution.
- Mitigating Factor: The system uses serverless/managed infrastructure with no open file system.
- Justification: Designated as "Not at Risk" based on a structural lack of malware execution vectors; validated via annual architectural reviews.

4. EDUCATION, BACKGROUND CHECKS, AND CONTRACTORS (PCI 12.6.3.1 & 12.7)

* Annual Security Training: All personnel with administrative or development access to the portal must complete a basic review of security threats (specifically phishing, social engineering, and secure credential protection) at least once every 12 months.
* Personnel Screening: Prior to granting any individual full administrative access to the member database or AWS configurations, a standard reference and background validation will be executed by the HOA board to mitigate insider threats.

5. THIRD-PARTY SERVICE PROVIDER (TPSP) MANAGEMENT (PCI 12.8)

* The HOA utilizes industry-leading, verified PCI-compliant partners for portal operations:
1. Infrastructure Provider: Amazon Web Services (AWS)

2. Core Payment Processor: Authorize.net

* Compliance Tracking: The Web Administrator will verify and confirm that both AWS and Authorize.net maintain current, active Attestations of Compliance (AoC) at least once every 12 months.

6. 24/7 INCIDENT RESPONSE STRATEGY (PCI 12.10 & 12.10.3)

* Designated Contact: The [Insert Title, e.g., HOA Web Administrator / Board Treasurer] is officially designated as the primary security contact available on a 24/7 basis to handle suspected or confirmed data anomalies or platform compromise alerts.

* Incident Playbook: In the event of a suspected security event (e.g., automated AWS GuardDuty alert,

unexplained page script modification, or notification of a brute-force attack):

1. Isolation: The Administrator will immediately use the AWS Console to restrict or sever public inbound network traffic to the web application.

2. Triage: Inspect AWS CloudTrail logs to identify the source IP, affected resources, and compromised user credentials.

3. Remediation: Revoke compromised keys/passwords, reverse unauthorized configurations, and redeploy known-good application code from our secure repository.

4. Communication: If any breach indicators impact member accounts, notify the HOA board and affected members transparently within required regulatory timelines.

7. NO COMPENSATING CONTROLS

*No compensating controls are used. All PCI DSS requirements are met directly.

=====

SECTION 13: THIRD PARTY SERVICE PROVIDERS

=====

Effective Date: [Insert Date]

Last Reviewed: [Insert Date]

Review Cycle: Annually

Amazon AWS - Website and database hosting

Zoho - Email service

[Authorize.net](https://authorize.net) - Merchant services